5EWB COURSES | AI-POWERED CYBERSECURITY
Assessment 01: Security Foundations Report

Student Name: Soham Satish Bandekar
Batch / Group: October 2026
Date of Submission: 5 Nov 2026

Task A | Secure a Student Account

A1 & A2. Risk Assessment and Mitigation Matrix

Risk ID	Risk Description	Asset at Risk	CIA Element Impacted	Practical Control	Control Limitation
R01	Reusing a short, weak password across email and learning portal.	Account Credentials / Academic Portal	**Confidentiality & Integrity:** Compromise of one account grants access to both, letting attackers read data or alter coursework.	Deploy a **unique, strong passphrase** for each portal managed by a trusted password manager.	If the master password for the manager is weak, all stored credentials are compromised.
R02	Approving unexpected or uninitiated sign-in prompts blindly.	Active User Session / Account Access	**Confidentiality & Integrity:** Grants unauthorized access to external malicious actors trying to bypass secondary checks.	Implement **context-aware MFA** requiring matching a displayed number on screen rather than simple push taps.	Does not prevent compromise if the user is actively tricked via reverse-proxy phishing.
R03	Postponing critical operating system and software device updates.	Student Laptop / Local System Files	**Confidentiality, Integrity, & Availability:** Leaves system open to known exploits, malware, or ransomware attacks.	Enable **automatic system updates** scheduled during non-working hours.	Updates can occasionally cause software incompatibility issues or temporary instability.
R04	Storing the sole copy of a critical academic project locally on one device.	Course Project Files / Data	**Availability:** Hardware failure, theft, or physical damage results in absolute, irreversible loss of data.	Establish a **3-2-1 backup strategy** utilizing automated cloud storage and an external drive.	Requires regular monitoring to confirm backups run successfully; introduces storage costs.
R05	Sharing an active, signed-in session with an unauthenticated friend.	Signed-in Portal Session / Local Data	**Confidentiality & Integrity:** The friend can intentionally or accidentally read, delete, or submit data as Mira.	Mandate **screen-locking habits** (\(Win + L\)) and create a restricted local Guest Account for shared use.	Relies entirely on human discipline and operational consistency to execute every time.

Prioritisation and Justification of First Three Actions

1. **Control for R01 (Unique Passphrase + Password Manager):** This is the highest priority. Eliminating credential reuse stops immediate account takeover vectors across unrelated platforms.
2. **Control for R04 (Automated Multi-Location Backups):** Immediate availability protection. If the hardware suffers sudden failure or malware encryption, the academic work remains safe.
3. **Control for R02 (Context-Aware MFA Safeguards):** Prevents external threat actors from capitalizing on stolen credentials by blocking unauthorized authentication streams.

A3. Authentication versus Authorisation

- **Authentication** is the technical verification of identity—proving *who* you are. For example, when Mira types her username, password, and completes her MFA token, the learning portal confirms she is indeed Mira.
- **Authorisation** is the enforcement of permissions—determining *what* you are allowed to do after identity confirmation. For example, once authenticated, Mira is authorized to view her own grades and submit assignments, but she is strictly unauthorized to view other students' records or modify class materials.

Task B | Analyse a Suspicious Message

B1. Warning Signs Analysis Table

Quote from Evidence	Security Analysis / Reason for Scrutiny
`"From: Scholarship Desk <awards@campus-awards.example>"`	**Look-alike Domain:** The sender's domain uses `campus-awards.example`, which deviates from the institution's official domain (`campus.example`).
`"Reply-To: help@personal-awards.example"`	**Mismatched Routing:** Replies are explicitly routed away from the sending system to an external, unverified destination domain.
`"Subject: FINAL WARNING - scholarship expires in 20 minutes"`	**Artificial Urgency:** Classic psychological social engineering tactic designed to induce panic and bypass logical verification.
`"enter your college password and OTP"`	**Credential Harvesting:** Legitimate academic portals never request secret authentication keys or One-Time Passwords via email links.
`"Do not contact the college office because their system is unavailable."`	**Isolation Tactic:** A targeted effort to prevent the recipient from conducting out-of-band verification through official campus channels.

B2. Safe Verification Process

1. **Ignore and Close:** Do not interact with the message, click the embedded links, or reply to the email addresses provided.
2. **Out-of-Band Validation:** Open a fresh browser tab and manually enter the known, official URL (`https://campus.example`) or dial the phone number printed directly on your official student ID card.
3. **Why Technical Anchors Alone Fail:**

- An **HTTPS lock icon** only proves that communications to that specific web server are encrypted; it does not prove the server owner is legitimate. Attackers routinely secure free SSL certificates for malicious domains.
- A **Familiar Display Name** ("Scholarship Desk") can be typed manually by any sender without technical validation; it carries zero cryptographic proof of identity.

B3. Student Incident Response Plan

1. **Immediate Containment:** Access the official security dashboard from a trusted device, change the account password immediately, and select "Sign out of all active sessions".
2. **Official Notification:** Forward the full suspicious email along with its technical headers to the authorized campus IT security team (`abuse@campus.example`).

3. **Security Audit:** Review recent account logs for unauthorized changes, verify that default recovery email addresses/phone numbers have not been altered, and check for unexpected changes in financial aid configurations.

B4. Technical Limitations & Missing Evidence

- **Unestablished Fact:** The absolute authenticity of the sending infrastructure cannot be proven by the raw text layout alone (e.g., whether the domain was spoofed or sent from a legitimately registered malicious asset).
- **Required Additional Evidence:** Full email transport headers containing IP routing paths along with **SPF (Sender Policy Framework)**, **DKIM (DomainKeys Identified Mail)**, and **DMARC** validation status records.

Task C | Triage a Sign-In Alert

C1. Incident Timeline

- **09:00 - 09:01 IST [Fact]:** Logs record a successful password submission followed by an approved Multi-Factor Authentication (MFA) request for user `student07` originating from IP address `192.0.2.10`.
- *Interpretation:* Authorized, baseline student activity occurring from the standard classroom network egress point.
- **10:14 - 10:15 IST [Fact]:** Two sequential password authentication attempts fail for user `student07` originating from an unknown external IP address `198.51.100.23`.
- *Interpretation:* An unauthorized party or automated tool is actively attempting to guess the account password.
- **10:16 - 10:17 IST [Fact]:** A successful password entry is registered from IP `198.51.100.23`, immediately followed by a denied MFA request.
- *Interpretation:* The external attacker successfully acquired the password, but their initial entry was temporarily blocked because the student explicitly denied the unexpected notification.
- **10:18 - 10:20 IST [Fact]:** A secondary MFA prompt is approved from IP `198.51.100.23`, resulting in a finalized application session creation. User states: *"I approved a prompt because I thought it would stop the repeated requests."*
- *Interpretation:* The account was fully compromised due to the student succumbing to **MFA Push Fatigue**.

C2. Hypothesis Generation and Investigative Steps

- **Primary Explanation:** An external threat actor harvested the user's password, initiated an authentication loop from IP `198.51.100.23`, and successfully gained unauthorized session access by fatiguing the student into approving the prompt.
- **Alternative Explanation:** The student left the classroom, connected via an external cellular provider or VPN that assigned IP `198.51.100.23`, mistyped their password twice, rejected the first prompt in confusion, and then completed their own login.
- **Distinguishing Investigative Checks:**

1. **User-Agent String Analysis:** Inspect the web browser and OS footprints across the log timestamps to determine if the device characteristics changed at 10:14.
2. **Application Activity Audit:** Review what files or settings were touched immediately following the 10:20 session creation to flag anomalous behavior.

C3. Prioritised IT Remediation Actions

1. **Session Invalidation & Account Lock:** Force an immediate global revocation of all active sessions for `student07` and temporarily disable the account to sever the attacker's active path.
2. **Out-of-Band Credential Reset:** Coordinate directly with the student via an established offline channel to perform a verified password reset and audit registered MFA phone lines/devices.
3. **Forensic Evidence Preservation:** Snapshot and isolate the authentication logs, firewall records, and target network traffic linked to both source IPs for subsequent analysis.

C4. Incident Summary

On 18 October 2026, user account `student07` suffered a suspected compromise via an MFA fatigue attack. Following consecutive failed password attempts originating from an external IP (`198.51.100.23`), a correct password was supplied. The true user explicitly confessed to approving a subsequent MFA prompt to stop persistent alerts, resulting in unauthorized session establishment at 10:20. Device characteristics and explicit geolocation details remain unverified. The priority is flagged as High due to active unauthorized access. Next action: Revoke all active sessions, lock the account, and conduct a secure out-of-band password reset.

Task D | Review an AI Security Answer

D1. Technical Corrections of Flawed AI Assertions

1. **Flawed Claim:** *"The email is safe because it uses HTTPS."*
- **Correction:** HTTPS provides encryption in transit; it does not validate the integrity or legitimacy of the domain host. Phishing sites universally use HTTPS.
2. **Flawed Claim:** *"The sign-in logs prove that the person using 198.51.100.23 stole the password."*
- **Correction:** Network logs document source addresses, not human identity. An IP address can be a proxy, VPN, or public gateway; it does not prove *who* executed the theft.
3. **Flawed Claim:** *"MFA prevents every account compromise."*
- **Correction:** MFA can be bypassed through multiple active methodologies, including session hijacking, prompt fatigue exploitation, and reverse-proxy setups.
4. **Flawed Action:** *"Delete the suspicious logs..."*
- **Correction:** Deleting logs erases critical forensic evidence needed to investigate the scope of a breach and violates incident response compliance standards. Logs must be archived securely.
5. **Flawed Action:** *"...send the student's password to support so they can test it."*

- **Correction:** Passwords should never be shared or transmitted in cleartext. Support agents do not need plaintext credentials to troubleshoot account states.

D2. Optimized AI Security Prompt

text

Analyze the provided synthetic sign-in logs and user statement for student07. Separate observed facts within the logs from assumptions or interpretations. Evaluate potential security risks without assuming the absolute identity of individuals behind IP addresses. Do not request, suggest, or include any real personal data, passwords, or secrets. State any missing details or uncertainties explicitly.
Use code with caution.

D3. Corrected Professional Security Advice

The suspicious email represents a credential harvesting attempt utilizing a look-alike domain structure and false situational urgency. Subsequent log analysis confirms an account compromise affecting `student07`. Although multi-factor authentication was active, the threat actor bypassed the control via an MFA push fatigue attack, exploiting the student's compliance to silence continuous notification alerts. This allowed unauthorized session creation from an unrecognized external IP address (`198.51.100.23`). Immediate remediation requires the IT team to terminate all active sessions globally, lock the account, verify MFA device registration details, and implement a mandatory out-of-band password change. Students must be reminded never to approve unprompted authentication requests.

D4. Declarations and Trusted Documentation References

- **AI-Use Declaration:** AI assistance was used exclusively for document formatting, alignment, and structural layout review. All investigative analysis, timeline breakdowns, and technical explanations were generated manually using supplied evidence.
- **Reference 1: CISA (Secure Our World):** Guidelines highlighting core account habits: implementing unique passphrases, recognizing phishing indicators, and managing secondary authentication alerts securely.
- **Reference 2: NIST (Generative AI Profile, AI 600-1):** Directives advising data professionals to aggressively verify AI claims against source material to mitigate data confabulations.
